

Secure System Design Project for Telecom Company

This project requires designing secure company systems for a telecom organisation based on the following environment and constraints.

Company Profile and Scope

- **Industry:** Telecom
- **Total Personnel:** 550 individuals (500 employees, 50 contractors)
- **Applications:** 30 applications in use
- **Vendor Relationships:** 3 systems vendors
- **Infrastructure Mix:** Hybrid (Some services are **on-premise**, and some services are in the **cloud**).

Project Requirements and Submission Guidelines

- **Group Formation:** Groups 1 through 10 will participate.
- **Topic Selection:**
 - Each group **must select only 1** of the 10 available topics.
 - Topics cannot be duplicated; each of the 10 topics can be selected by only one group.
- **Deliverable:** Submit your complete security design as a **PDF** document.
- **Submission Deadline:** **1:40 PM** sharp.
- **Scope per Group:** **One design per group.**
- **Collaboration and Resources:**
 - **AI (Artificial Intelligence) tools are allowed.**
 - **Group discussion and collaboration are allowed.**

Here are the 10 topics for this exam.

1. Identity and Access Management (IAM)

You should design a robust IAM system that covers authentication (MFA for all users), authorisation (RBAC/ABAC models), identity lifecycle management for employees, contractors, and vendors, privileged access management (PAM) for administrative accounts, and single sign-on (SSO) integration across 30 applications. Consider contractor access expiration and just-in-time access provisioning.

2. Network Security Architecture

Design a segmented network with DMZ for public-facing services, internal zones for different security levels, micro-segmentation for critical assets, secure connectivity between on-premise and cloud environments (VPN/SD-WAN), and network access control (NAC) for device authentication. Include firewall placement strategy and network isolation principles.

3. Perimeter Defence and Threat Detection

Implement layered defences including next-generation firewalls (NGFW), intrusion detection systems (IDS) for monitoring, intrusion prevention systems (IPS) for active blocking, DDoS protection services, web application firewalls (WAF) for application-layer protection, and email security gateways. Define monitoring strategies and alert thresholds.

4. Data Security and Encryption

Establish data classification policies, encryption standards for data at rest and in transit, data loss prevention (DLP) solutions, database security controls, secure file sharing mechanisms, backup encryption, and key management systems. Address both cloud and on-premise data protection requirements.

5. Endpoint Security

Deploy endpoint detection and response (EDR) solutions, antivirus/anti-malware protection, mobile device management (MDM) for BYOD scenarios, patch management systems, application whitelisting, and host-based firewalls. Consider the diverse endpoint ecosystem across 550 users.

6. Cloud Security Architecture

Design security for cloud services, including cloud access security broker (CASB), cloud security posture management (CSPM), secure configuration of cloud resources, identity federation between on-premise and cloud, cloud workload protection, and shared responsibility model implementation across IaaS, PaaS, and SaaS services.

7. Application Security

Implement secure software development lifecycle (SDLC), application security testing (SAST/DAST), API security controls, secure coding standards, vulnerability management for 30 applications, third-party component scanning, and security requirements for both legacy and modern applications across hybrid environments.

8. Security Operations and Monitoring

Establish a Security Operations Centre (SOC) framework, including SIEM implementation for log aggregation and correlation, security monitoring dashboards, incident response procedures, threat intelligence integration, security orchestration and automated response (SOAR), and 24/7 monitoring capabilities.

9. Governance, Risk, and Compliance (GRC)

Develop security policies and procedures, risk assessment methodology, compliance framework (GDPR, ISO 27001, industry-specific regulations), security awareness training programs, vendor risk management for contractors, audit logging requirements, and continuous compliance monitoring across hybrid infrastructure.

10. Business Continuity and Disaster Recovery

Design backup and recovery strategies, disaster recovery plans for both cloud and on-premise systems, high availability architecture, failover mechanisms, recovery time objectives (RTO) and recovery point objectives (RPO) for critical systems, incident response playbooks, and regular testing procedures.

Exercise Considerations:

- Budget constraints and prioritisation
- Integration challenges between cloud and on-premise systems
- Scalability for future growth
- User experience vs. security balance
- Contractor temporary access workflows
- Zero-trust architecture principles
- Regulatory compliance requirements specific to the industry